# LockBit Ransomware: Analysis of a Ransomware-as-a-Service Threat

**Cybersecurity Capstone Research**

October 2026

**Prepared by**

Ajayi Rafiu Olakunle

# Abstract

This report examines LockBit as an example of how ransomware has developed into an organised cybercrime service. LockBit is useful for a cybersecurity case study because public sources document its malware versions, affiliate model, attack methods, and the law-enforcement action taken against its infrastructure. The report explains how a ransomware-as-a-service (RaaS) operation divides responsibilities between its core operators and affiliates, then reviews the stages commonly seen in an intrusion, from gaining access to stealing data and disrupting systems.

The research draws mainly on government advisories, law-enforcement announcements, and MITRE ATT&CK. CISA and partner agencies reported that LockBit was the most deployed ransomware variant worldwide in 2022 and described approximately 1,700 attacks in the United States and about US$91 million in U.S. ransom payments through 2023 (CISA et al., 2023). In February 2024, Operation Cronos disrupted important parts of LockBit's infrastructure. The U.S. Department of Justice later announced charges against an alleged administrator (Europol, 2024; U.S. Department of Justice, 2024a, 2024b).

The report also includes a controlled Wazuh lab exercise. In that exercise, a test file was copied and given a simulated LockBit-style extension. No encryption was performed and no real data was affected. Wazuh recorded a privileged command event, but the evidence did not show that a dedicated LockBit detection rule had fired. This distinction is important: the lab demonstrates basic event visibility, not detection of the real LockBit malware family.

# Introduction

Ransomware is no longer just a program that locks files and demands payment. Many modern campaigns combine unauthorised access, credential theft, movement between systems, data theft, and attempts to interfere with recovery. These activities can disrupt an organisation even before files are encrypted.

LockBit is a useful case study because it operated through a ransomware-as-a-service model. Instead of one team carrying out every stage of every attack, the core operation maintained the ransomware platform and related services while affiliates conducted intrusions. This arrangement helped the operation scale, but it also meant that individual incidents could differ in their tools and techniques (CISA et al., 2023).

The aim of this capstone is to examine LockBit from a defender's point of view. It reviews the operation's development, describes a representative attack lifecycle, maps documented behaviours to MITRE ATT&CK, and identifies controls that can help an organisation detect or limit ransomware activity. A small Wazuh exercise is included to show how endpoint telemetry can support an investigation and where basic monitoring has limits.
The research relies primarily on public material from CISA and partner agencies, MITRE ATT&CK, Europol, and the U.S. Department of Justice. These sources provide technical and operational context, while the lab section reports only the evidence collected in the student's environment.

# Aim and objectives

**Aim:** To assess LockBit as a ransomware threat and use the findings to develop practical defensive recommendations.

## Objectives:

- ➢ Describe LockBit's development and its ransomware-as-a-service business model.
- ➢ Explain the main stages commonly associated with a LockBit intrusion.
- ➢ Map representative behaviours to MITRE ATT&CK techniques.
- ➢ Document a controlled Wazuh simulation and interpret its results accurately.
- ➢ Recommend security controls that reduce the likelihood and impact of ransomware incidents.

# Methodology

This study uses qualitative threat-intelligence analysis. It prioritizes primary sources such as government cybersecurity advisories, law-enforcement announcements, and MITRE ATT&CK entries. Secondary reporting is used for context where appropriate.

The work was completed in three stages. First, LockBit was described in terms of its operating model, versions, and history. Second, publicly documented behaviours were organised into a general attack lifecycle. Third, selected behaviours were associated with ATT&CK techniques and considered alongside defensive controls. A separate, non-destructive lab exercise used Wazuh to observe command and file-change activity. The exercise did not use LockBit malware.

# Threat profile: LOCKBIT

LockBit is a financially motivated ransomware operation associated with the RaaS model. Public reporting describes activity from around 2020 and later versions that included LockBit 2.0, LockBit 3.0/Black, LockBit Green, and variants targeting Linux and VMware ESXi environments (CISA et al., 2023). MITRE ATT&CK maintains separate entries for LockBit 2.0, LockBit 3.0, and the StealBit exfiltration tool (MITRE ATT&CK, 2025a, 2025b, 2025c).

The affiliate structure matters to defenders. The core operation can maintain the platform and associated services, while affiliates bring their own access methods and post-compromise tools. As a result, two incidents associated with the same ransomware brand may not share an identical sequence of activity. Detection should therefore consider behaviour and supporting telemetry, rather than relying only on a malware name or file extension.

## Evolution and major milestones:

Public reporting describes several stages in LockBit's development. LockBit 2.0 appeared in 2021, followed by LockBit 3.0 in 2022. Later reporting also described LockBit Green and versions aimed at Linux and ESXi systems. The September 2022 leak of the LockBit 3.0 builder is a reminder that malware code can circulate beyond the group that originally developed it. For defenders, this makes behaviour-based monitoring important: a tool or code sample may be reused by actors who are not part of the original operation (CISA et al., 2023; MITRE ATT&CK, 2025a).

In February 2024, Operation Cronos disrupted important LockBit infrastructure. Europol reported that authorities from ten countries took action against the operation's infrastructure, including 34 servers. The U.S. Department of Justice stated that LockBit had targeted more than 2,000 victims and had received more than US$120 million in ransom payments at the time of the disruption (Europol, 2024; U.S. Department of Justice, 2024a). These figures should be attributed to the agencies that reported them rather than presented as independently measured totals.

## Ransomware-as-a-service model:

The RaaS model divides work between platform operators and affiliates. The operators maintain the ransomware service and related infrastructure; affiliates use the service during

attacks. This arrangement can lower the technical barrier for criminals who already have a way into a victim's network but do not have the ability or resources to build their own ransomware.

There are two practical consequences for security teams. First, tools and access methods can vary between incidents, so attribution based on one utility alone is weak. Second, defenders need to look for suspicious combinations of activity. Legitimate administration tools may be used during normal work, but unusual use of those tools—especially when paired with abnormal logins, privilege changes, or large numbers of file operations—may warrant investigation (CISA et al., 2023).

# Attack lifecycle analysis

A LockBit-related incident should be investigated as a sequence of behaviours, not as a single file or alert. The exact sequence depends on the affiliate and the victim environment. The following stages summarise patterns described in public reporting.

### ➢ Initial access

Reported entry methods include phishing, exploitation of internet-facing applications, external remote services, and misuse of valid accounts. Relevant ATT&CK techniques include T1566, T1190, T1133, and T1078 (CISA et al., 2023).

### ➢ Execution and persistence

After access, an attacker may use command shells, PowerShell, services, or other administrative functions to run tools and maintain access. Investigators should correlate these events with the account used, parent process, host, and time.

Privilege escalation and defence evasion

Reported activity includes attempts to gain higher privileges, access credentials, change security settings, clear logs, or interfere with endpoint protection. Such activity may provide an opportunity to respond before widespread encryption occurs.

### ➢ Discovery

Attackers may enumerate systems, network services, shared folders, domain information, and storage. This helps them identify valuable systems and plan their next actions.

Lateral movement

Remote desktop, SMB or administrative shares, and remote-access tools may be used to move between systems. Unusual administrative logins, unexpected connections between workstations and servers, and access outside normal working patterns deserve attention.

### ➢ Collection and exfiltration

Data may be collected and transferred out of the environment before encryption. StealBit is documented as a LockBit-associated exfiltration tool. Investigators should examine unusual archive creation, outbound transfers, and unexpected use of cloud or file-sharing services (CISA et al., 2023; MITRE ATT&CK, 2025c).

## ➢ Impact

The final stage may involve file encryption, stopping services, deleting logs, or interfering with recovery. Relevant ATT&CK techniques include T1486, T1490, and T1489. These behaviours should be treated as separate findings unless the evidence shows that they occurred together.

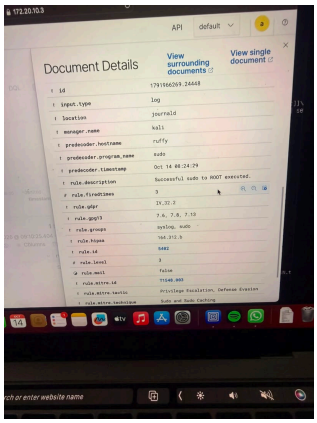
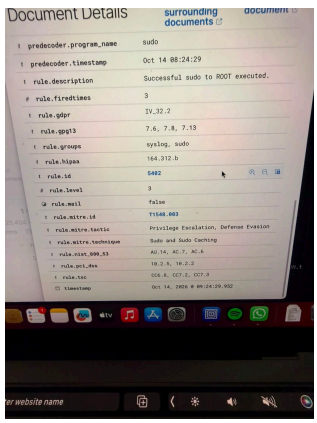
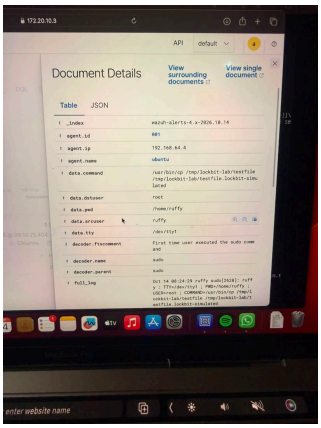
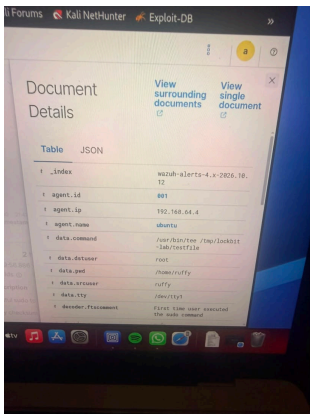
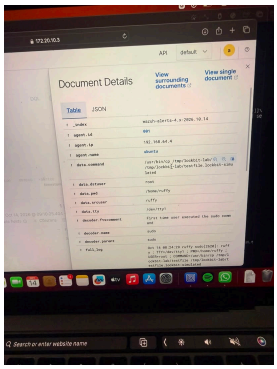
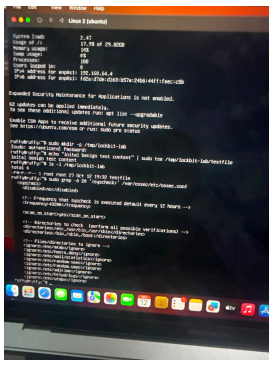
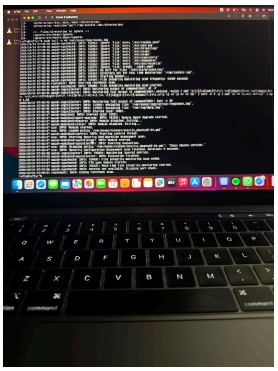
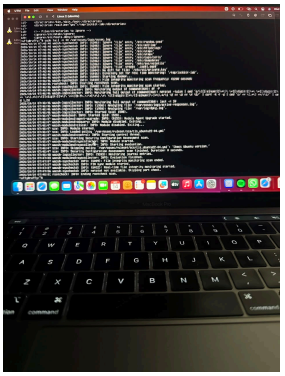
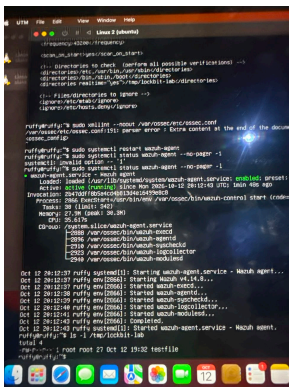
# MITRE ATT&CK mapping

MITRE ATT&CK provides a common vocabulary for describing adversary behaviour. The mappings below are representative examples drawn from the source report and public threat reporting; they are not a claim that every technique occurred in the student's lab.

| Tactic / stage | ATT&CK IDs | Example behaviour |
|---|---|---|
| Initial Access | T1190; T1133; T1566; T1078 | Exploit public-facing application; external remote services; phishing; valid accounts |
| Execution | T1059.001; T1059.003; T1569.002 | PowerShell; Windows Command Shell; service execution |
| Persistence | T1547; T1078 | Boot or logon autostart execution; valid accounts |
| Privilege Escalation | T1548.002; T1484.001 | Bypass User Account Control; group policy modification |
| Defence Evasion | T1562.001; T1070.001; T1070.004; T1027 | Impair defences; clear Windows event logs; file deletion; obfuscated files or information |
| Credential Access | T1003; T1003.001; T1555.003 | OS credential dumping; LSASS memory; credentials from web browsers |
| Discovery | T1046; T1082; T1083 | Network service discovery; system information discovery; file and directory discovery |
| Lateral Movement | T1021.001; T1021.002 | Remote Desktop Protocol; SMB/Windows administrative shares |
| Collection / Exfiltration | T1560.001; T1567.002; T1005 | Archive collected data; exfiltration to cloud storage; data from local system |
| Impact | T1486; T1490; T1489; T1485 | Data encrypted for impact; inhibit system recovery; service stop; data destruction |

CISA's advisory and MITRE's entries provide the source basis for these mappings (CISA et al., 2023; MITRE ATT&CK, 2025a, 2025b, 2025c). Always check the current ATT&CK pages before final submission because technique descriptions and software mappings may change.

## Wazuh lab simulation: findings and analysis

### ➢ Observed evidence

On 14 October 2026 at 09:24:29 (UTC+1), Wazuh agent 001 on Ubuntu (192.168.64.4) generated rule 5402, titled “Successful sudo to ROOT executed.” The alert was level 3 and belonged to the syslog and sudo groups.

The event was collected through journald and processed by the Wazuh manager running on Kali.

The user `ruffy`, working from `/dev/tty1` in `/home/ruffy`, ran the following command with root privileges:

/usr/bin/cp /tmp/lockbit-lab/testfile /tmp/lockbit-lab/testfile.lockbit-simulated

The decoder described this as the user's first recorded sudo use. The event details should be retained as lab evidence, and the timestamp and IP address should be checked against the screenshots or exported Wazuh event before final submission.

➢ **Interpretation**

The command copied a test file and gave the copy a filename containing `.lockbit-simulated`. This imitated a visible file-marking indicator without encrypting the file. No real data was affected. Wazuh detected privileged command execution; the available evidence does not show that Wazuh identified the file operation as ransomware activity.

This distinction limits the conclusion that can be drawn. The event is useful for demonstrating that command telemetry was collected, but it is not proof of a LockBit-specific alert or of successful ransomware detection. The interpretation depends on the command and its test filename, rather than on a dedicated Wazuh classification.

**ATT&CK mapping of the lab event**

- ➢ T1548.003 — Abuse Elevation Control Mechanism: Sudo and Sudo Caching. The report states that this mapping was associated with the Wazuh rule.
- ➢ T1486 — Data Encrypted for Impact. This is only a contextual analyst mapping; the simulation did not encrypt data.
- ➢ T1078.003 — Valid Accounts: Local Accounts. The activity was performed by the local user `ruffy`; this does not, by itself, establish malicious account use.

*The mappings should not be described as proof that all three techniques were executed. In particular, T1486 was not directly demonstrated because no encryption occurred.*

**Evidence limitations**

The available evidence consists of a level-3 sudo alert and a single file-copy operation. It does not show bulk file changes, a ransom note, encryption, data exfiltration, or recovery inhibition. More evidence would be needed to evaluate whether a dedicated detection rule reliably identifies ransomware-like behaviour.

**Problems encountered and how they were resolved**

➢ **Wazuh agent did not start consistently**

The Ubuntu agent initially failed to start cleanly. The configuration was reviewed, the service was restarted with systemctl, and its status was checked until it reported active (running).

➢ **Configuration-file errors**

Edits to `ossec.conf` produced XML/configuration errors, including an extra closing or root element. The relevant syscheck section was inspected, and the project continued after the agent was running and its log reported that real-time file-integrity monitoring had started.

➢ **Test directory was missing**

The first attempt to create demonstration files failed because `/tmp/lockbit-lab` did not exist. The directory was created with `sudo mkdir -p /tmp/lockbit-lab`, after which the sample files could be created and listed.

➢ **File-integrity events were not immediately visible**

The command event appeared before the expected syscheck results. The configuration and `ossec.log` were checked, then a known file was modified and searched for by filename in the dashboard. The resulting file-change event provided separate evidence of FIM activity.

➢ **Command logging and file-integrity monitoring were confused**

A logged `tee` command showed that command activity was recorded, but it did not independently prove that a file-integrity event had been generated. The test was repeated by changing a known file and searching for that filename.

➢ **Limited computing resources**

The host has an Intel Core i5 processor, 8 GB of RAM, and 256 GB of storage. The lab was kept small by using Kali and Ubuntu and closing unnecessary applications.

## Project limitations

➢ **No real LockBit execution**

The exercise used harmless file creation, copying, and modification. It did not execute LockBit or reproduce the full behaviour of the malware. The results demonstrate basic monitoring, not detection of the actual malware family.

➢ **Limited behaviour coverage**

The demonstration focused on command telemetry and file changes. It did not test encryption, persistence, credential theft, lateral movement, exfiltration, or backup deletion.

➢ **File-integrity monitoring does not establish intent**

A file change can be legitimate or malicious. Analysts must correlate it with process information, user context, timing, and other telemetry before drawing conclusions.

➢ **Detection rules were not fully validated**

The lab showed that relevant events could be observed, but it did not establish that a high-confidence LockBit-specific rule had fired.

➢ **Small, isolated environment**

Testing involved a small number of virtual systems and a limited set of files. Results may differ in a larger network or under different operating systems, policies, workloads, and agent versions.

➢ **No production incident-response exercise**

The project did not test enterprise-wide isolation, forensic imaging, scoping, or recovery from backups. Those response actions were discussed rather than tested against a live incident.

➢ **Temporary test directory**

The simulation used `/tmp/lockbit-lab`, which may not persist after a reboot. It is suitable for a short test but should not be treated as durable evidence storage.

➢ **Network and dashboard settings affect visibility**

Agent communication and dashboard results depend on network configuration, IP addresses, registration, selected time range, and search fields. Incorrect settings can make events difficult to locate.

**How the limitations were managed**

- ➢ The simulation remained non-destructive and was restricted to the Ubuntu test directory.
- ➢ Conclusions were limited to the command and file-change activity that was actually observed.

- Screenshots of the terminal, configuration, service status, logs, and Wazuh event details were retained where available.

- The report distinguishes simulated indicators from real LockBit execution.

- ATT&CK mappings are presented as contextual analysis, not proof that every technique occurred.

## Recommendations

- Build a ransomware detection baseline aligned with MITRE ATT&CK and validate it with safe simulations.
- Require phishing-resistant multifactor authentication for privileged and externally accessible accounts wherever feasible.
- Apply least privilege and separate standard user accounts from administrative accounts.
- Patch internet-facing systems according to a documented, risk-based service-level agreement.
- Segment critical servers, administrative systems, backups, and user networks.
- Centralise endpoint, authentication, DNS, proxy, firewall, and cloud logs so analysts can correlate activity.
- Protect endpoint detection tools and backup infrastructure against tampering.
- Develop detections for credential access, unusual remote services, defence evasion, suspicious data transfers, and rapid file modification.
- Run periodic ransomware tabletop exercises and record actions, gaps, and follow-up owners.
- Test backup restoration regularly; the existence of backups does not prove that recovery will work.
- Track useful measures such as time to detect, time to contain, endpoint coverage, privileged-account MFA coverage, patch compliance, and restoration-test success.
- Repeat threat-informed validation after significant changes to systems, identity controls, or security tooling.

# Conclusion

LockBit demonstrates how ransomware can operate as a wider criminal service rather than a single piece of malware. Its affiliate model, changing technical capabilities, data-extortion practices, and documented law-enforcement disruption make it a useful subject for a cybersecurity capstone.

The main defensive lesson is to investigate behaviour in context. A suspicious command, an unusual login, or a file change may be important, but none should automatically be treated as proof of ransomware. Analysts need to connect identity, endpoint, network, and file activity, then compare the combined evidence with known attack patterns.

The Wazuh exercise adds practical value because it shows both what the lab could observe and what it could not establish. The system recorded privileged command execution, while the simulated file operation did not demonstrate encryption or a dedicated LockBit detection. Stating these limits clearly makes the findings more credible. Further work should validate file-integrity coverage, add a reproducible event timeline, and test detections using harmless simulations.

# References

CISA, FBI, MS-ISAC, ACSC, CCCS, NCSC-UK, ANSSI, BSI, CERT NZ, & NCSC NZ. (2023, June 14). Understanding ransomware threat actors: LockBit (AA23-165A). Cybersecurity and Infrastructure Security Agency.

Europol. (2024, February 20). Law enforcement disrupts world's biggest ransomware operation — LockBit was the most deployed ransomware variant across the world. European Union Agency for Law Enforcement Cooperation.

Federal Bureau of Investigation. (2024, February 20). FBI Cyber Deputy Assistant Director Brett Leatherman's remarks at press conference announcing the disruption of the LockBit ransomware group. U.S. Department of Justice.

MITRE ATT&CK. (2025a). LockBit 2.0 (S1199). MITRE.

MITRE ATT&CK. (2025b). LockBit 3.0 (S1202). MITRE.

MITRE ATT&CK. (2025c). StealBit (S1200). MITRE.

Sophos. (2024). GOLD MYSTIC: Threat profile detail. SophosLabs.

U.S. Department of Justice. (2024a, February 20). U.S. and U.K. disrupt LockBit ransomware variant. U.S. Department of Justice.

U.S. Department of Justice. (2024b, May 7). U.S. charges Russian national with developing and operating LockBit ransomware. U.S. Department of Justice.